Ethical Hacking Assignment 1

ITA1435 Ethical Hacking ASSIGNMENT 1

NAME: D Poornachandra
Reg No:192424267

.

CO1

CO1: Apply the foundational concepts of ethical hacking, including the types of hackers, ethical principles, legal frameworks, and the role of responsible disclosure in cybersecurity.

Assignment 1 Title : Design and Develop a Complete Ethical-Hacking Engagement Framework for a University's Authorized Security-Assessment Programme

Scenario — University Authorized Security-Assessment Programme

A university is establishing an Authorized Security-Assessment Programme to test the security of its student portal, learning-management system, email service and campus network before a major upgrade. The programme must cover approximately 20 systems and 50 staff initially, but the framework is expected to remain usable as the programme grows to the whole university and begins to include external, third party assessors.

The management has not yet fixed how ethical-hacking engagements will be governed. Testing may be requested by different departments, carried out by internal staff or external testers, and may touch systems that hold personal data. The team is concerned that an unstructured approach may lead to unauthorized access, legal exposure, damage to live systems, unclear scope or uncoordinated disclosure of discovered vulnerabilities.

You have been appointed as the Ethical-Hacking Governance Team. Your responsibility is not merely to describe hacking tools. You must investigate the requirements, design a complete engagement framework, construct reusable components and documents, integrate the different parts, validate the design through a walkthrough and defend the final framework using evidence.

The final framework must clearly distinguish between what is authorized, what is legal, and what is appropriate for the university. The team is expected to make governance decisions independently and justify why the framework is suitable for the given scenario. No live exploitation is performed; all work stays at the design, documentation and isolated-lab level.

Design Challenge

Create and validate an integrated ethical-hacking engagement framework for the university programme. The framework must define how an engagement is authorized, how scope and rules of engagement are set, how the relevant laws are respected, how different types of attackers are modelled, how discovered vulnerabilities are disclosed responsibly, and how an isolated lab is used where hands-on testing is required.

Your final design must be usable in practice and must demonstrate interaction among the selected components rather than treating each document or rule as an isolated example. Every major governance decision must be supported by evidence and a clear explanation of the trade-offs involved.

TASK 1 – Formulate the Enquiry and Framework Blueprint 4 Marks • Convert the scenario into a formal set of engagement-governance requirements. Identify the systems in scope, the stakeholders, the expected activities and the constraints.

• Create a framework blueprint showing how authorization, scope, legal compliance, threat modelling, lab testing and disclosure will cooperate in the proposed programme.

• Formulate at least four enquiry questions that your framework must answer, such as who authorizes a test, what is in scope, which laws apply and how findings are disclosed.

• Define at least five design criteria and use them as acceptance criteria for the final framework.

Evidence Expected

A requirements-to-governance blueprint, enquiry questions, design criteria and a clear rationale showing how the proposed framework addresses the scenario.

TASK 1 – Formulate the Enquiry and Framework Blueprint

1.1 Introduction

Ethical hacking is the process of testing computer systems and networks with proper permission to identify security weaknesses.

The university wants to develop an Authorized Security-Assessment Programme to protect its student portal, Learning Management System (LMS), email service and campus network.

The proposed framework provides rules for authorization, scope, legal compliance, threat modelling, ethical testing, isolated lab testing and responsible disclosure.

1.2 Requirements Identification

Systems in scope:

1. Student Portal
2. Learning Management System (LMS)
3. University Email Service
4. Campus Network
5. Database Servers
6. Authentication Systems

Initially, the programme covers approximately 20 systems and 50 staff members.

Stakeholders:

- University Management – Provides final approval.
- IT Security Team – Manages security assessments.
- System Administrators – Provide system information.
- Ethical Hackers – Perform authorized testing.
- Legal Team – Checks legal requirements.
- Data Protection Officer – Protects personal information.
- External Assessors – Conduct approved security assessments.

1.3 Expected Activities

- Identifying security vulnerabilities.
- Checking authentication and access controls.
- Reviewing network security.
- Performing controlled security tests.
- Recording security findings.
- Preparing vulnerability reports.
- Fixing identified security problems.

1.4 Framework Blueprint

ISO 29147: The basics every business should know (2026) | Konfirmity

konfirmity.com

The proposed framework follows these stages:

1. Authorization: Obtain written permission from university management.
2. Scope Definition: Identify allowed and prohibited systems.
3. Legal Compliance: Follow applicable cybersecurity and data-protection laws.
4. Threat Modelling: Identify possible attackers and their motivations.
5. Lab Testing: Perform practical testing in an isolated environment.
6. Vulnerability Reporting: Record identified security weaknesses.
7. Responsible Disclosure: Report findings to the university.
8. Remediation: Fix vulnerabilities and verify the corrections.

1.5 Enquiry Questions

1. Who has the authority to approve an ethical-hacking engagement?

2. Which university systems are allowed for testing?
3. Which cybersecurity and data-protection laws must be followed?
4. How can different types of hackers be classified?
5. How can vulnerabilities be reported safely?
6. How can practical testing be performed without damaging university systems?

1.6 Design Criteria and Acceptance Criteria

Design criteria	**Acceptance criteria**
Authorization	Every test must have written approval.
Scope management	All allowed and prohibited systems must be listed.
Legal compliance	Relevant laws must be identified and mapped to controls.
Data protection	Personal information must be protected.
Safety	Practical testing must use an isolated lab.
Disclosure	Every finding must have a documented reporting process.
Scalability	Framework must support internal and external testers.

1.7 Rationale

This framework is suitable because it provides a structured process for managing security assessments. It reduces unauthorized access, protects student information, prevents system damage and creates clear responsibilities for all stakeholders.

It also supports future expansion from 20 systems to the entire university.

TASK 2 – Design a Hacker Threat Model and Classification 4 Marks • Design a classification of the types of hackers relevant to the university, such as white-hat, black-hat, grey-hat, script kiddie, hacktivist, insider and state-sponsored actors.
• Map each type to its motivation, typical capability and likely targets within the university. • Establish clear criteria and naming so that an actor can be classified consistently. • Demonstrate at least two alternative ways of classifying one borderline actor, then choose and justify the final classification.

Evidence Expected
A documented hacker threat model, classification criteria, a mapping table, rejected alternatives and a justified final classification.

TASK 2 – Design a Hacker Threat Model and Classification

2.1 Introduction

A hacker is a person who uses technical knowledge to access, examine or manipulate computer systems and networks.

Hackers are classified according to their intentions, permissions, skills and activities.

2.2 Types of Hackers

Ethical Hacking & Reverse Engineering — Week 1 | by Ayoade Akintayo (PhD) | Mar, 2026 | Medium

Understanding Hackers in Cybersecurity

Atak Zero-Day: Poznaj zagrożenie i dowiedz się, jak się przed nim chronić

4

2.3 Hacker Classification Table

Hacker type	**Motivation**	**Capability**	**Possible university target**
White Hat	Improve security	High technical skills	Student portal
Black Hat	Steal data or money	Advanced skills	University database
Grey Hat	Curiosity or recognition	Medium to high	LMS
Script Kiddie	Entertainment	Basic skills and ready-made tools	University website
Hacktivist	Political or social causes	Medium to high	University website
Insider	Personal benefit or revenge	Knowledge of internal systems	Staff accounts

State-Sponsored	Espionage or national interest	Very advanced	Research servers and networks

2.4 Classification Criteria

The following criteria are used to classify hackers:

1. Authorization: Whether the person has permission.
2. Motivation: Whether the person wants to improve security or cause harm.
3. Technical Skills: Basic, intermediate or advanced.
4. Target: The system or information being accessed.
5. Impact: Whether the activity causes damage or data loss.

2.5 Borderline Actor Example

Scenario: A student discovers a security weakness in the university student portal without permission. The student accesses a limited amount of information and informs the university.

This person can be classified in two ways:

Alternative 1 – Grey Hat Hacker

- Accessed the system without permission.
- Did not intend to cause damage.
- Reported the vulnerability.

Alternative 2 – Black Hat Hacker

- Accessed a system without authorization.
- Viewed information without permission.
- Violated security boundaries.

2.6 Final Classification

The person is classified as a Grey Hat Hacker based on the stated motivation and reporting behaviour, but the unauthorized access remains unacceptable and may create legal consequences.

A good intention does not automatically make unauthorized access legal.

2.7 Conclusion

The threat model helps the university understand possible attackers, their motivations and their targets. It also helps the security team select suitable protection methods.

TASK 3 – Create an Ethics and Code-of-Conduct Module 4 Marks • Define the ethical principles that govern an authorized engagement, such as written authorization, agreed scope, confidentiality, integrity, avoiding harm and honest reporting.

• Design rules or checks that help detect or prevent unethical actions during an engagement. • Construct scenario cases containing acceptable, borderline and unacceptable actions and show how the code of conduct responds to each.

• Explain how the module preserves trust and keeps the engagement lawful and professional.

Evidence Expected

A reusable code-of-conduct module, decision rules, scenario test cases and evidence that the rules separate acceptable from unacceptable actions.

TASK 3 – Create an Ethics and Code-of-Conduct Module

3.1 Introduction

An ethical code of conduct provides rules that ethical hackers must follow during security assessments.

Its main purpose is to ensure that testing is authorized, safe, confidential and professional.

3.2 Ethical Principles

1. Written Authorization: Obtain permission before testing.
2. Agreed Scope: Test only approved systems.
3. Confidentiality: Do not share student or staff information.
4. Integrity: Do not modify or destroy university data.
5. Avoid Harm: Avoid activities that affect live services.
6. Honest Reporting: Report all findings correctly.
7. Accountability: Maintain records of testing activities.
8. Responsible Disclosure: Report vulnerabilities only to authorized people.

3.3 Rules to Prevent Unethical Actions

Rule	**Security check**
Permission check	Verify the signed authorization form.
Scope check	Confirm the target is approved.
Time check	Perform testing during approved hours.
Data check	Never copy unnecessary personal data.
Safety check	Stop testing if system damage occurs.
Reporting check	Submit findings to the security team.

3.4 Ethical Scenario Test Cases

Scenario	Action	Decision
Tester checks an approved LMS in the agreed time	Allowed	Acceptable
Tester requests additional access without approval	Needs permission	Borderline
Tester accesses student records without authorization	Prohibited	Unacceptable
Tester shares vulnerabilities on social media	Prohibited	Unacceptable
Tester reports a vulnerability confidentially	Allowed	Acceptable

3.5 Decision Rules

- If written authorization is available and the activity is within scope, testing can continue.
- If the scope is unclear, testing must be paused until clarification.
- If personal information is exposed, the tester must stop unnecessary access and inform the security team.
- If unexpected damage occurs, testing must stop immediately.
- If a tester violates the code of conduct, the engagement may be suspended.

3.6 Importance of the Code of Conduct

The code of conduct protects the university, students and testers. It builds trust between the security team and management and ensures that all security assessments are conducted professionally.

TASK 4 – Construct a Legal-Compliance Mapping 4 Marks • Map the engagement to the relevant provisions of the Information Technology Act, 2000 on unauthorized access and data, and compare them with an international law such as the Computer Fraud and Abuse Act.
• Build a table of offences, obligations and penalties related to unauthorized access and data protection. • Connect each legal requirement to a specific control in the engagement framework. • Decide and justify which legal requirements apply when a test touches systems that hold personal data.

Evidence Expected
A legal-compliance mapping, an offences-and-penalties table, the controls linked to each requirement and a justified conclusion on which laws apply.

TASK 4 – Create a Legal-Compliance Mapping

4.1 Introduction

Legal compliance is important because ethical hacking involves accessing computer systems and sometimes handling personal information.

The university must follow Indian cybersecurity laws and consider international laws when applicable.

4.2 Indian Information Technology Act, 2000

The Information Technology Act, 2000 provides legal rules relating to computer systems, unauthorized access, data damage and disclosure of information.

Important sections include:

Section 43 – Unauthorized Access

- Covers accessing computer systems without permission.
- Includes downloading, copying or extracting information.
- Covers damaging or disrupting computer systems.
- Provides for compensation for damage.

Section 66 – Computer-Related Offences

- Applies when acts covered under Section 43 are done dishonestly or fraudulently.
- Punishment can extend to three years of imprisonment, a fine up to ₹5 lakh, or both.

Section 72 – Breach of Confidentiality and Privacy

- Deals with unauthorized disclosure of information obtained under powers provided by the Act.
- Provides for a penalty up to ₹5 lakh under the amended provision.

Section 72A – Disclosure of Information in Breach of Lawful Contract

- Covers certain unauthorized disclosures of personal information obtained under a lawful contract.

- Provides for a penalty up to ₹25 lakh under the amended provision.

IndiaCode+4

4.3 International Law – Computer Fraud and Abuse Act (CFAA)

The Computer Fraud and Abuse Act is a United States law.

It deals with:

- Unauthorized access to protected computers.
- Obtaining information without permission.
- Causing damage to computer systems.
- Password-related offences.
- Computer fraud and related activities.

Under 18 U.S.C. §1030, penalties vary according to the offence and circumstances. Some first offences carry imprisonment of up to one year, while more serious offences can carry longer terms.

The CFAA applies where its United States jurisdictional requirements are met. It does not automatically apply to every Indian university assessment.

US Code+1

4.4 Legal Offences and Penalties Table

Law	Offence	Penalty / consequence
IT Act Section 43	Unauthorized access or damage	Compensation
IT Act Section 66	Dishonest or fraudulent computer-related acts	Up to 3 years or ₹5 lakh fine or both
IT Act Section 72	Certain unauthorized disclosures	Penalty up to ₹5 lakh
IT Act Section 72A	Disclosure violating lawful contract in specified circumstances	Penalty up to ₹25 lakh
CFAA Section 1030	Unauthorized access and computer damage	Varies by offence; imprisonment and fines

Note: Penalties are based on the amended provisions and depend on the facts and applicable legal procedure.

4.5 Legal Requirements and Framework Controls

Legal requirement	Framework control
No unauthorized access	Written authorization
No data damage	Safe testing rules
Confidentiality	Non-disclosure agreement
Protection of personal data	Data minimization and restricted access
Prevention of illegal disclosure	Responsible disclosure process
External tester accountability	Signed contract and authorization

4.6 Personal Data Protection

The university stores sensitive information such as:

- Student names and contact details.
- Email addresses.
- Academic records.
- Login credentials.
- Staff information.

The Digital Personal Data Protection Act, 2023 (DPDP Act) and the Digital Personal Data Protection Rules, 2025 are also relevant to the programme.

An important point is that the DPDP Act has phased commencement. As of 3 November 2026, many of its main data-processing obligations are scheduled to commence 18 months after the November 2025 notification, in May 2027. Therefore, the university must check the commencement status of each provision rather than assume that every provision is already in force.

The framework should prepare for these requirements by using access restrictions, data minimization, secure storage, confidentiality agreements and incident reporting.

E-Gazette+2

4.7 Which Laws Apply?

The Indian IT Act applies to the university's relevant computer systems and activities in India.

The DPDP Act applies according to its notified commencement provisions and its scope concerning digital personal data.

The CFAA is considered when a relevant system, activity or conduct has a sufficient United States connection to fall within its jurisdiction.

4.8 Conclusion

Legal compliance protects the university from legal problems and ensures that ethical hacking is conducted with proper permission and respect for personal information.

TASK 5 – Create a Scope and Rules-of-Engagement Document 4 Marks • Design a scope and rules-of-engagement (RoE) document that defines in-scope and out-of-scope systems, testing windows, permitted and prohibited techniques and escalation paths. • Create rules for recording and verifying the written authorization behind each engagement. • Establish clear naming and boundaries so that an out-of-scope request can be detected. • Construct at least one transformation of the RoE into a pre-engagement checklist.

Evidence Expected
A complete RoE document, authorization-verification rules, scope boundaries and a derived pre engagement checklist.

TASK 5 – Create a Scope and Rules-of-Engagement Document

5.1 Introduction

Rules of Engagement (Roe) define how ethical hackers can perform security testing. They explain which systems are allowed, what activities are permitted and what activities are prohibited.

5.2 Scope and Rules-of-Engagement Document

Document Name: University Security Assessment – Roe

Objective: To identify security weaknesses without affecting university operations.

In-Scope Systems:

1. Student Portal.
2. Learning Management System.
3. University Email Service.
4. Campus Network.
5. Approved Test Databases.
6. Authentication Servers.

Out-of-Scope Systems:

1. Personal student devices.

2. External bank payment systems.
3. Third-party cloud systems without written permission.
4. Other universities' networks.
5. Personal email accounts.
6. Production databases containing real student records unless specifically approved for a limited assessment.

5.3 Testing Schedule

Activity	Schedule
Assessment start	Approved date
Testing time	9:00 AM – 5:00 PM
Testing days	Monday – Friday
Emergency support	Available during testing
Final report	Within 5 working days after testing

5.4 Permitted Techniques

- Network configuration review.
- Vulnerability scanning.
- Password policy review.
- Authentication testing.
- Access-control testing.
- Web application security checks.
- Log and security configuration review.

5.5 Prohibited Techniques

- Denial-of-Service (DoS) attacks.
- Destructive malware.
- Unauthorized data extraction.
- Modifying student records.
- Attacking third-party systems.
- Testing outside approved hours.
- Sharing confidential information.

5.6 Authorization Verification Rules

Before testing, the security team must verify:

1. Written permission from authorized management.
2. Names of approved testers.
3. Approved target IP addresses and system names.
4. Testing start and end dates.
5. Permitted testing techniques.
6. Emergency contact details.
7. Signatures of responsible authorities.

5.7 Escalation Process

If a tester discovers a serious problem:

1. Stop the testing activity.
2. Record the issue.
3. Inform the team leader.
4. Contact the IT security manager.
5. Inform university management if necessary.
6. Resume testing only after receiving approval.

5.8 Pre-Engagement Checklist

The Rules of Engagement are converted into the following checklist.

No.	Checklist item	Status
1	Written authorization received	Yes / No
2	Scope clearly defined	Yes / No
3	Tester identity verified	Yes / No
4	Legal requirements checked	Yes / No
5	Testing schedule approved	Yes / No
6	Lab environment prepared	Yes / No
7	Emergency contacts available	Yes / No
8	Disclosure procedure agreed	Yes / No

Acceptance Rule: Testing can begin only when all mandatory checklist items are completed.

5.9 Conclusion

The RoE document prevents unauthorized testing and clearly defines the responsibilities of testers. It also protects university systems from accidental damage.

TASK 6 – Build an Authorization and Disclosure Layer 5 Marks • Create an authorization workflow covering the request, approval, written sign-off and recording of each engagement.
• Design a responsible (coordinated) disclosure process with a reporting format, remediation window and timeline, and compare it with full disclosure and bug-bounty approaches.
• Develop operations for logging approvals and status updates and for deciding when disclosure may proceed.
• Create rules for choosing between coordinated and full disclosure for a given finding. • Demonstrate that this layer interacts correctly with the rules-of-engagement and legal-compliance components.

Evidence Expected

An authorization workflow, a responsible-disclosure process, logging and decision operations, disclosure rules and evidence of interaction with the other components.

TASK 6 – Build an Authorization and Disclosure Layer

6.1 Introduction

The authorization and disclosure layer controls the beginning and ending of an ethical-hacking engagement.

It ensures that testing is approved before starting and that vulnerabilities are reported responsibly.

6.2 Authorization Workflow

Penetration Test Service Provider: How to Apply

iscb.cybersecurity.my

Steps:

1. Request Submission: Department submits a security-testing request.
2. Initial Review: Security team checks the purpose and requirements.
3. Scope Approval: Approved systems and testing activities are identified.
4. Legal Verification: Legal team checks applicable laws and contracts.
5. Management Approval: Authorized university officer approves the assessment.
6. Written Sign-Off: Authorization form is signed by responsible persons.
7. Engagement Registration: Unique engagement ID is generated.

8. Testing Begins: Testers start only after all approvals are verified.
9. Report Submission: Findings are submitted to the security team.
10. Closure: Assessment is closed after remediation and final review.

6.3 Authorization Record

Every engagement must contain:

- Engagement ID.
- Department name.
- System name.
- Tester name.
- Approved scope.
- Testing period.
- Approval date.
- Management signature.
- Status.

Example:

Field	**Sample value**
Engagement ID	UASP-001
Department	CSE
System	Student Portal
Tester	Security Team A
Status	Approved
Testing period	10–15 November 2026

6.4 Responsible Disclosure Process

Responsible disclosure means reporting discovered vulnerabilities privately to the responsible organization and giving it time to fix the problem before public disclosure.

Disclosure stages:

1. Tester identifies a vulnerability.
2. Tester records technical details.
3. Tester submits a confidential report.
4. Security team verifies the finding.

5. University assigns severity.
6. Technical team fixes the problem.
7. Tester verifies the correction.
8. Finding is closed.

6.5 Disclosure Timeline

Activity	Proposed timeline
Initial reporting	Within 24 hours of discovery
Acknowledgement	Within 2 working days
Vulnerability verification	Within 5 working days
Critical vulnerability remediation target	Within 7 days
High vulnerability remediation target	Within 15 days
Medium vulnerability remediation target	Within 30 days
Low vulnerability remediation target	Within 60 days

These are proposed university service targets, not statutory legal deadlines. If a fix cannot be completed within the target, management must approve a documented mitigation and revised deadline.

6.6 Comparison of Disclosure Methods

Method	Meaning	Advantage	Limitation
Coordinated Disclosure	Private reporting and agreed publication	Protects users	Requires cooperation
Full Disclosure	Vulnerability details are published publicly	Creates awareness	Attackers may misuse details
Bug Bounty	Researchers receive rewards for valid findings	Encourages security research	Requires budget and clear rules

Selected Method: Coordinated Vulnerability Disclosure.

It is suitable because the university handles confidential student and staff information.

6.7 Logging Operations

Every action must be recorded in an engagement register.

Example:

Date	Activity	Responsible person	Status

10-11-2026	Request submitted	Department Head	Received
11-11-2026	Scope approved	Security Manager	Approved
12-11-2026	Testing started	Ethical Hacker	Active
13-11-2026	Finding reported	Tester	Submitted
15-11-2026	Vulnerability fixed	IT Team	Resolved

6.8 Disclosure Decision Rules

- Critical vulnerabilities must be immediately escalated.
- Personal information must never be published in a report.
- Public disclosure requires written university approval.
- If remediation is delayed, the security manager must escalate the issue.
- If a third-party service is affected, its owner must be contacted through the approved contractual process.

6.9 Interaction with Other Components

The authorization layer checks the signed Roe before testing.

The legal-compliance layer checks whether the activity is permitted.

The finding report transfers vulnerability information to the disclosure process.

Therefore, authorization, scope, legal compliance and disclosure work together.

6.10 Conclusion

This layer ensures that every engagement is approved, recorded and completed through a responsible vulnerability-reporting process.

TASK 7 – Design an Isolated Ethical-Hacking Lab 5 Marks • Design a safe, isolated lab using a Kali Linux machine and one or more authorized target machines on a host-only network with reserved addresses such as 192.168.56.0/24.

• Specify the components, roles and connectivity of the lab and the steps used to record its configuration.

• Develop at least two operations, such as verifying connectivity between the machines and recording the lab setup.

• Construct a small comparison between a host-only and a NAT lab network and justify the chosen design.

• Explain how the lab keeps all testing authorized and contained within the isolated environment.

Evidence Expected
An isolated-lab design, a component and connectivity specification, verification operations, a comparison of network options and a justified final lab model.

TASK 7 – Design an Isolated Ethical-Hacking Lab

7.1 Introduction

An isolated ethical-hacking lab is a safe environment used to practise security testing without affecting real university systems.

The proposed lab uses Kali Linux as the testing machine and an authorized target machine.

7.2 Lab Components

1. Kali Linux – Testing machine.
2. Ubuntu Linux – Target machine.
3. VirtualBox – Virtualization software.
4. Host-only Network – Isolated communication.
5. Firewall – Controls network traffic.
6. Lab Documentation – Records configurations.

7.3 Lab Network Design

New Project: Virtual Pentesting Lab | securityfox

codingfox86.github.io

Network Configuration:

Component	IP Address
Kali Linux	192.168.56.10
Ubuntu Target	192.168.56.20
Network	192.168.56.0/24
Network Type	Host-only
Gateway	Not required for isolated communication

Both machines communicate only through the isolated host-only network.

7.4 Lab Setup Procedure

1. Install VirtualBox on the computer.
2. Create a Kali Linux virtual machine.

3. Create an Ubuntu target virtual machine.
4. Open VirtualBox network settings.
5. Select Host-only Adapter for both machines.
6. Configure the IP addresses.
7. Start both virtual machines.
8. Check network connectivity.
9. Record the lab configuration.

7.5 Operation 1 – Verify Connectivity

The ping command checks whether two authorized lab machines can communicate.

On Kali Linux:

ping 192.168.56.20

Expected output:

64 bytes from 192.168.56.20

64 bytes from 192.168.56.20

64 bytes from 192.168.56.20

This confirms connectivity if the target permits ICMP traffic.

7.6 Operation 2 – Record Lab Configuration

The following commands help record the network configuration.

ip addr

Displays the IP address information.

ip route

Displays network routing information.

date

Records the current date and time.

The output can be saved in a lab documentation file.

ip addr > lab-record.txt

ip route >> lab-record.txt

date >> lab-record.txt

7.7 Host-Only vs NAT Comparison

Feature	Host-only	NAT
Network isolation	High	Limited
Internet access	Normally unavailable	Available through host
VM communication	Yes	Depends on NAT configuration
External access	Restricted	Outbound connectivity available
Security	Better isolation	Requires additional controls

7.8 Selected Lab Design

Host-only network is selected.

Reasons:

- Provides better isolation.
- Prevents accidental external testing.
- Supports communication between lab machines.
- Protects university production systems.
- Makes testing easier to control.

7.9 Safety Rules

1. Only approved virtual machines can be tested.
2. No real student data is used.
3. No unauthorized external network access is allowed.
4. Lab configurations must be documented.
5. Snapshots must be taken before experiments.
6. Testing must stop if the lab connects to an unauthorized network.

7.10 Conclusion

The isolated lab provides a controlled environment for practical ethical-hacking activities. It reduces risk and ensures that testing remains within approved boundaries.

TASK 8 – Develop a Reusable Document Library 4 Marks • Create a minimum of four reusable engagement documents supporting the framework, including at least one authorization form and one finding report.

• Use sensible default fields where appropriate and explicitly design the content of each document. • At least one document, such as the finding report, must produce a structured output that integrates

with another component of the framework.
• Create test entries that demonstrate valid, boundary and invalid inputs and document the expected result.

Evidence Expected
A reusable document library, documented fields, a structured report output, test entries and evidence of integration with the framework.

TASK 8 – Develop a Reusable Document Library

8.1 Introduction

A document library contains reusable forms and reports required for managing ethical-hacking engagements.

The university can use standard documents for every security assessment.

8.2 Reusable Documents

Four important documents are designed below.

Document 1 – Authorization Form

Document Name: University Security Assessment Authorization Form

Field	Description
Engagement ID	Unique assessment number
Department	Requesting department
System Name	System to be tested
Tester Name	Authorized tester
Testing Purpose	Reason for assessment
Start Date	Testing start date
End Date	Testing end date
Approved Activities	Permitted testing methods
Management Approval	Signature
Security Manager Approval	Signature

Example:

- Engagement ID: UASP-001
- Department: CSE
- System: Student Portal

- Tester: Security Team A
- Status: Approved

Document 2 – Scope and RoE Form

Document Name: Rules of Engagement Form

Field	Description
Scope	Approved systems
Out-of-Scope	Prohibited systems
Testing Window	Approved time
Permitted Techniques	Allowed activities
Prohibited Techniques	Restricted activities
Emergency Contact	Security manager
Approval Status	Approved / Rejected

Document 3 – Vulnerability Finding Report

Document Name: Security Vulnerability Report

Field	Description
Finding ID	Unique finding number
Engagement ID	Related engagement
Vulnerability Name	Name of weakness
Affected System	Target system
Severity	Critical / High / Medium / Low
Description	Details of vulnerability
Evidence	Safe supporting evidence
Risk	Possible impact
Recommendation	Suggested solution
Status	Open / In Progress / Closed

Sample Finding:

Field	Sample value
Finding ID	FIND-001
Engagement ID	UASP-001

Vulnerability	Weak Password Policy
Affected System	Student Portal
Severity	High
Risk	Unauthorized account access
Recommendation	Apply strong password rules and MFA
Status	Open

Document 4 – Final Assessment Report

Document Name: University Security Assessment Final Report

Contents:

1. Executive Summary.
2. Assessment Objective.
3. Systems Tested.
4. Testing Methodology.
5. Vulnerabilities Identified.
6. Risk Classification.
7. Recommended Solutions.
8. Remediation Status.
9. Conclusion.
10. Approval and Sign-Off.

8.3 Structured Report Integration

The finding report uses structured fields that can be transferred to the disclosure register.

Example:

{

"finding_id": "FIND-001",

"engagement_id": "UASP-001",

"system": "Student Portal",

"vulnerability": "Weak Password Policy",

"severity": "High",

"status": "Open",

"disclosure": "Submitted"

}

This structured output connects the document library with the authorization and disclosure layer.

8.4 Document Validation Test Cases

Test case	Input	Expected result
Valid	Correct engagement ID and signatures	Accepted
Boundary	Testing ends on approved end date	Accepted
Invalid	Missing authorization signature	Rejected
Invalid	Unknown system name	Rejected
Invalid	Missing finding severity	Rejected
Valid	Finding contains all mandatory fields	Accepted

8.5 Benefits

- Saves time.
- Maintains standard documentation.
- Reduces mistakes.
- Improves accountability.
- Supports future university expansion.
- Makes security assessments easier to manage.

8.6 Conclusion

The document library provides reusable forms for authorization, scope management, vulnerability reporting and final assessment. It also connects reports with the disclosure process.

TASK 9 – Integrate, Test and Refine the Framework 4 Marks • Integrate the components created in Tasks 2-8 into one coherent engagement framework. • Construct a realistic walkthrough of an authorized assessment from request and authorization, through testing in the isolated lab, to responsible disclosure.

• Design systematic test cases covering missing authorization, out-of-scope requests, legal conflicts and delayed disclosure.

• Record the problems encountered during the walkthrough and show how the framework was refined to address them.

Evidence Expected

A reproducible integrated framework, a workflow walkthrough, systematic test cases, refinement evidence and a final corrected framework.

TASK 9 – Integrate, Test and Refine the Framework

9.1 Introduction

Integration means combining all the designed components into one complete ethical-hacking framework.

The framework connects authorization, threat modelling, ethics, legal compliance, scope management, lab testing, documentation and disclosure.

9.2 Integrated Framework

Ethical Hacking: Navigating Legal and Ethical Boundaries in Cyber Security - Octopus | Built for Researchers

octopus.ac

Integrated workflow:

1. Department submits an assessment request.
2. Management verifies and approves authorization.
3. Security team defines scope and RoE.
4. Legal team checks legal requirements.
5. Testers follow the ethical code of conduct.
6. Testing is performed in the isolated lab.
7. Vulnerabilities are recorded in finding reports.
8. Security team verifies the findings.
9. Responsible disclosure is performed.
10. IT team fixes the vulnerabilities.
11. Final report is submitted and engagement is closed.

9.3 Realistic Walkthrough

Scenario: The university wants to test the security of its student portal.

Step	Activity	Result
1	Department submits request	Request received
2	Management approves assessment	Authorization completed
3	Security team defines scope	Student Portal approved
4	Legal verification	Compliance checked

5	Tester prepares isolated lab	Lab ready
6	Controlled testing	Weak password policy identified
7	Finding report created	FIND-001 generated
8	Security team verifies finding	Finding confirmed
9	IT team applies correction	Password policy improved
10	Final verification	Finding closed

9.4 Systematic Test Cases

Test case	Situation	Expected result
TC01	Missing authorization	Testing must be rejected
TC02	Out-of-scope system requested	Testing must be stopped
TC03	Legal compliance issue	Engagement must be paused
TC04	Delayed vulnerability disclosure	Escalation must occur
TC05	Valid authorization and scope	Testing can begin
TC06	Critical vulnerability found	Immediate escalation

9.5 Problems Encountered and Refinements

Problem	Solution
Missing signatures	Added mandatory authorization verification
Unclear testing scope	Added exact system and IP boundaries
Risk of personal data exposure	Added data minimization rules
Delayed reporting	Added disclosure deadlines
Accidental external connectivity	Selected host-only lab network
Missing documentation	Created standard reusable forms

9.6 Final Corrected Framework

After testing the framework, the following improvements were included:

- Mandatory written approval.
- Clear in-scope and out-of-scope boundaries.
- Legal compliance verification.
- Isolated lab environment.
- Standard vulnerability reporting.

- Defined disclosure timelines.
- Emergency escalation procedures.
- Regular review and monitoring.

9.7 Conclusion

The integrated framework provides a complete process for conducting authorized security assessments. The walkthrough demonstrates that every component works together to protect university systems.

TASK 10 – Create a Scalability and Governance Evaluation 4 Marks • Construct scenarios representing a small programme (one department) and a large programme (the whole university with external assessors), with the number of systems and testers involved. • Experiment with at least three important processes from the framework and record meaningful measures such as approval turnaround, scope coverage or the number of steps.
• Create a comparison table and at least one suitable chart or structured visualization. • Use the evidence to refine the governance of the framework rather than simply reporting the measures.

Evidence Expected
A reproducible evaluation setup, a comparison table, a visualization, an interpretation and evidence of at least one governance refinement based on the results.

TASK 10 – Create a Scalability and Governance Evaluation

10.1 Introduction

Scalability means the ability of a framework to support an increasing number of systems, departments and testers without losing security or control.

The proposed framework is evaluated using two programme scenarios.

10.2 Small and Large Programme Scenarios

Parameter	Small Programme	Large Programme
Coverage	One department	Whole university
Systems	5	200
Staff members	10	500
Testers	2	20
Departments	1	10
Assessment type	Internal	Internal and external
Approval	Department Head	Central Security Committee

Reporting	Manual register	Centralized reporting system

These figures are proposed evaluation assumptions for the assignment, not actual university measurements.

10.3 Evaluation of Important Processes

Three processes are evaluated:

1. Authorization approval.
2. Scope verification.
3. Vulnerability reporting.

The following figures are illustrative simulated measurements.

Process	**Small Programme**	**Large Programme**
Approval turnaround	2 days	5 days
Scope verification	1 day	3 days
Vulnerability reporting	1 day	2 days
Approval steps	4	6
Scope coverage	100%	98%

10.4 Structured Visualization

Approval turnaround comparison

Approval Turnaround Comparison

Illustrative simulated number of days required for approval.

0 days2 days4 days6 daysSmall ProgrammeLarge Programme

Scope coverage comparison

Scope Verification Coverage

Illustrative simulated percentage of systems covered by approved scope records.

0%25%50%75%100%Small ProgrammeLarge Programme

10.5 Evaluation and Interpretation

Small Programme:

- Approval is faster.
- Fewer systems need checking.
- Manual documentation is sufficient.
- Communication is easier.

Large Programme:

- Approval takes more time.
- More systems require scope verification.
- External testers need additional checks.
- Centralized reporting becomes necessary.

The large programme has a slightly lower scope coverage because of the increased number of systems and departments.

10.6 Governance Improvements

Based on the evaluation, the following improvements are proposed:

1. Introduce centralized authorization records.
2. Use unique engagement IDs.
3. Create department-wise security coordinators.
4. Automate scope verification.
5. Introduce external tester identity verification.
6. Maintain a centralized vulnerability register.
7. Conduct periodic governance reviews.

10.7 Conclusion

The evaluation shows that the framework can support both small and large programmes. Centralized approval, automated documentation and department-wise coordination will improve efficiency as the university expands.

TASK 11 – Defend the Framework Under a Changed Requirement 4 Marks • Changed requirement: the university now runs continuous and third-party assessments with stricter data-protection rules and a shorter disclosure timeline, and needs the framework to remain easy to govern and extend.
• Create a revised version of your framework by deciding which components should be retained, modified, replaced or redesigned.
• Construct at least one new or modified component that directly addresses the changed requirement and show how it integrates with the existing framework.
• Defend the final framework using evidence from your walkthrough, scalability evaluation, legal mapping and disclosure process.
• Identify at least two trade-offs or limitations that remain in your final design and propose future improvements.

Evidence Expected
A revised framework, demonstrated adaptation, an evidence-based defence, explicit trade-offs and a clear explanation of how the final design satisfies the changed requirements.

TASK 11 – Defend the Framework Under a Changed Requirement

11.1 Introduction

The university introduces a new requirement to conduct continuous security assessments and third-party assessments with stricter data-protection rules and shorter disclosure timelines.

The existing framework must be modified to support these changes.

11.2 Changed Requirements

The revised framework must support:

1. Continuous security assessments.
2. External security testers.
3. Stronger personal-data protection.
4. Shorter vulnerability disclosure timelines.
5. Centralized monitoring.
6. Easy expansion to more university systems.

11.3 Revised Framework Components

Component	Decision	Reason
Authorization	Modify	Add continuous approval and periodic renewal
Scope Management	Modify	Add system-wise scope records
Legal Compliance	Retain and update	Follow current legal requirements
Threat Modelling	Retain	Continue identifying attacker types
Ethics Module	Modify	Add third-party conduct requirements
Isolated Lab	Retain and expand	Support more testing machines
Disclosure	Redesign	Introduce shorter deadlines
Document Library	Modify	Add third-party agreement forms
Monitoring	Add	Track continuous assessment activities

11.4 New Component – Continuous Assessment Management Module

This module manages repeated security assessments and external testers.

Main Features:

- Register internal and external testers.
- Verify tester identity.
- Maintain approved system lists.
- Record assessment schedules.
- Monitor testing activities.
- Store vulnerability reports.
- Track remediation deadlines.
- Generate periodic security reports.

11.5 Revised Disclosure Timeline

Activity	**Revised timeline**
Initial vulnerability reporting	Within 4 hours
Acknowledgement	Within 8 hours
Critical finding escalation	Immediately
Verification	Within 24 hours
Critical remediation target	Within 72 hours
High remediation target	Within 7 days
Medium remediation target	Within 15 days
Low remediation target	Within 30 days

These are proposed internal service targets for the revised programme, not legal deadlines.

11.6 Third-Party Assessment Rules

External assessors must:

1. Sign a confidentiality agreement.
2. Receive written authorization.
3. Follow the approved scope.
4. Use approved testing environments.
5. Protect university information.
6. Submit vulnerability reports.
7. Follow university disclosure procedures.

8. Return or securely destroy assessment data after engagement closure.

11.7 Integration of the New Component

The new Continuous Assessment Management Module connects with the existing framework.

[What is a 3PAO: What it means and how it impacts businesses (2026) | Konfirmity]

[konfirmity.com]

Integration process:

1. External tester registers with the university.
2. Management verifies the tester.
3. Authorization is recorded.
4. Scope and legal requirements are checked.
5. Continuous assessment is scheduled.
6. Testing is performed in the approved environment.
7. Findings are recorded.
8. Critical issues are immediately escalated.
9. IT team performs remediation.
10. Final status is updated in the centralized register.

11.8 Evidence-Based Defence of the Framework

The proposed framework is supported by the following evidence:

Evidence	**Framework justification**
Task 4 – Legal Mapping	Protects against unauthorized access and improper data disclosure
Task 5 – RoE	Clearly defines permitted and prohibited testing
Task 7 – Isolated Lab	Reduces the risk of damage to live systems
Task 8 – Document Library	Provides reusable and standardized documents
Task 9 – Walkthrough	Demonstrates the complete engagement process
Task 10 – Scalability Evaluation	Demonstrates support for programme expansion
Task 6 – Disclosure Process	Ensures timely vulnerability reporting

11.9 Trade-Offs and Limitations

Trade-off 1 – Security vs Performance

Continuous security monitoring requires additional resources and may affect system performance.

Improvement: Use scheduled assessments and monitoring with controlled resource limits.

Trade-off 2 – Data Protection vs Testing Accuracy

Using synthetic data improves privacy, but some vulnerabilities may only appear with realistic data and workflows.

Improvement: Use anonymized or synthetic datasets and tightly controlled test accounts.

Trade-off 3 – Faster Disclosure vs Proper Verification

Shorter disclosure timelines may create pressure on the security team.

Improvement: Introduce priority-based reporting and immediate escalation for critical vulnerabilities.

Trade-off 4 – External Assessors vs Control

External testers may introduce additional privacy and confidentiality risks.

Improvement: Use contracts, identity verification, restricted access and continuous audit logs.

11.10 Future Improvements

- Develop a centralized security management dashboard.
- Introduce automated authorization tracking.
- Perform regular security audits.
- Improve third-party risk management.
- Introduce periodic staff security training.
- Review legal requirements whenever laws change.

11.11 Final Conclusion

The revised framework provides a complete and scalable approach for managing university security assessments.

It combines authorization, legal compliance, ethical rules, threat modelling, isolated lab testing, vulnerability reporting and responsible disclosure.

The framework is suitable for both internal and external security assessors. It also supports continuous assessment, stronger data protection and faster vulnerability reporting.

Therefore, the proposed framework helps the university maintain a secure, reliable and legally responsible IT environment.

OVERALL ASSIGNMENT CONCLUSION

The University Authorized Security-Assessment Framework provides a structured method for identifying and managing cybersecurity risks.

All 11 tasks are integrated into one governance model. The framework ensures that:

1. Every assessment receives written authorization.
2. Testing follows clearly defined scope boundaries.
3. Applicable legal requirements are respected.
4. Ethical principles are followed.
5. Practical testing takes place in an isolated lab.
6. Vulnerabilities are documented properly.
7. Responsible disclosure is followed.
8. Internal and external assessors are managed.
9. The programme can expand across the university.
10. Continuous security improvements are supported.

Final Result: The proposed framework helps the university identify vulnerabilities, protect personal information, reduce security risks and maintain a safe and legally responsible security-assessment programme.

REFERENCES

1. Information Technology Act, 2000 – Government of India.
2. Digital Personal Data Protection Act, 2023 – Government of India.
3. Digital Personal Data Protection Rules, 2025.
4. Computer Fraud and Abuse Act – United States, 18 U.S.C. §1030.
5. National Institute of Standards and Technology (NIST) – Cybersecurity Guidelines.
6. OWASP – Web Application Security Guidelines.
7. Kali Linux Official Documentation.
8. Oracle VirtualBox Documentation.

MARK DISTRIBUTION

Task	Marks
TASK 1 – Formulate	4
TASK 2 – Design	4
TASK 3 – Create	4
TASK 4 – Construct	4
TASK 5 – Create	4
TASK 6 – Build	5
TASK 7 – Design	5

TASK 8 – Develop	4
TASK 9 – Integrate,	4
TASK 10 – Create	4
TASK 11 – Defend	4
TOTAL	50